Common Azure AD/Microsoft 365 (M365) Security Misconfigurations

trimarcsecurity.com/hub-post/common-azure-ad-microsoft-365-m365-security-misconfigurations

Christina Morillo May 5, 2023

Updated: Dec 13, 2024

While a powerful tool for managing access to cloud applications and identities, Azure Active Directory (Azure AD) can be challenging to set up securely, leading to cloud misconfigurations, privileged escalation, and other vulnerabilities. Let's explore some of the most frequent misconfigurations the Trimarc identity and cloud security team typically encounter during a Microsoft Cloud Security Assessment (MCSA).

But first, what is Azure Active Directory?

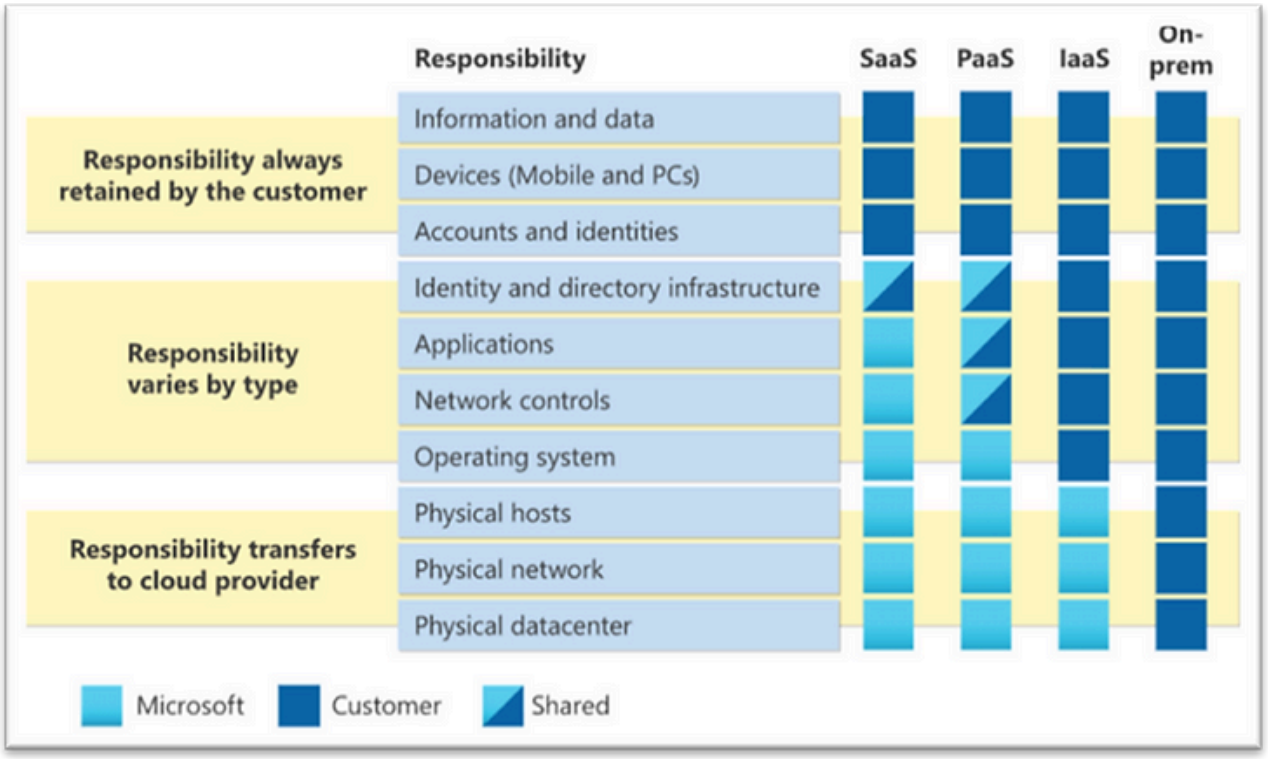
Azure Active Directory (Azure AD) is a cloud-based identity and access management solution operated by Microsoft. It is the most widely adopted service of its kind, enabling admins to easily manage user identities while controlling their access to both onsite and online resources. If you are a part of an organization that uses Office 365 or “Microsoft 365” (or “Microsoft Office 365”), then you have Azure AD as the directory service behind the scenes.

Azure AD and Active Directory may sound similar, but they are entirely different products. Azure AD is a cloud-based access management solution, while AD is an on-premises directory service. Thus, one cannot replace the other; both offer distinct benefits to organizations that depend upon them.

Unfortunately, as the utilization of cloud services and SaaS tools increase, misconfigurations also increase, which can cause vulnerabilities and unintentional disclosures. According to a 2021 report by Trend Micro, “misconfigurations might seem straightforward and avoidable, but they are the most significant risks to cloud environments-65-70% of all security challenges in the cloud arise from misconfiguration.”

Who Is responsible for the Security of my Cloud Environment?

When moving to the cloud one of the most important things you can do is educate yourself on shared responsibility. Having an in-depth understanding of the shared responsibility within the cloud space, and for your cloud provider of choice, is essential for understanding what you are accountable for and what falls to your cloud solution provider.



If we review Microsoft's shared responsibility matrix, we can see that the customer is responsible for preserving the security of your data and identities, on-premises resources, and any components you control - which may vary depending on service type. Irrespective of deployment type, you are the sole owner of your data, endpoints, accounts, and access management. As such, “the customer” is always responsible for enforcing secure access controls on how users connect to Azure AD and Microsoft 365.

As part of the Trimarc Microsoft Cloud Security Assessment (MCSA), we thoroughly analyze the security configuration of our customers Azure AD and Microsoft Office 365 environments. What we find is that many of the common misconfigurations can be quickly addressed with little to medium effort.

Common misconfigurations we see in enterprise environments:

1. Regular user accounts are members of the global administrator role (or other highly privileged role)

2. Unrestricted external sharing access for SharePoint/OneDrive

3. Multi-factor authentication (MFA) is not enforced (for user accounts and admins!)

4. Legacy “basic” authentication is still enabled

5. No configured emergency “break glass” accounts or they are not implemented according to best practices

Regular user accounts are members of the Global Administrator role

The Global Administrator role is the most privileged role in Azure AD. Members of this role have full administrative access to resources in their respective tenant. Suffice it to say that compromise of one of these accounts would result in the compromise of the Azure AD and Microsoft/Office 365 tenant as well as the Azure environment.

When thinking about privileged role access, we recommend:

• Ensuring only dedicated admin accounts are members of the Global Administrator role (follow the practice of least privilege).

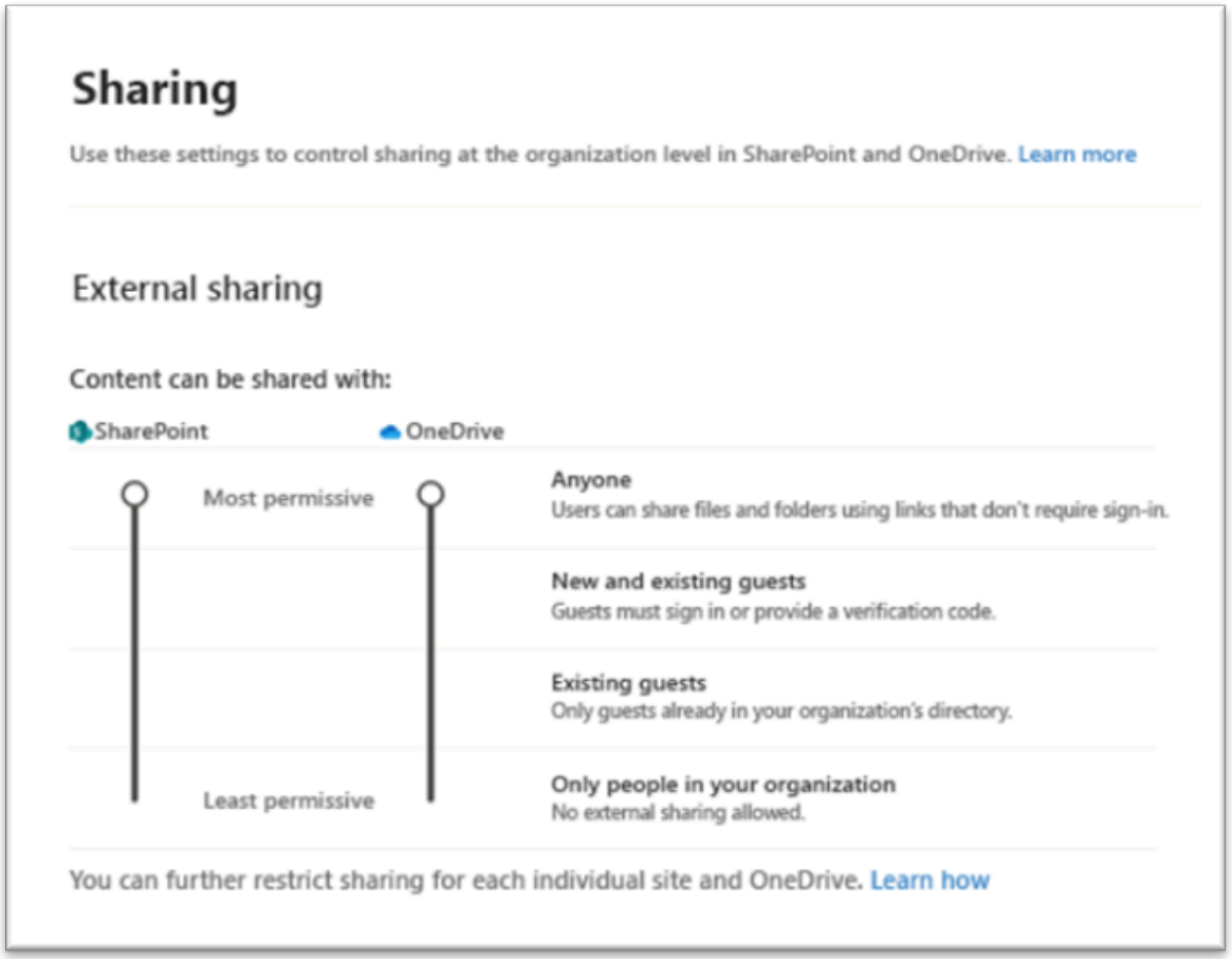
• Rather than assigning direct access to the Global Administrator role, enroll in Privileged Identity Management (PIM) and grant roles as eligible vs permanent access. Note that Privileged Identity Management does require P2 licensing for the accounts managed by PIM.

• Limiting the Global Administrator role to less than five privileged users (not regular user accounts).

• Enabling/enforcing MFA for all administrator accounts.

Unrestricted external sharing access (ex. SharePoint/OneDrive)

We typically find this set to the “Anyone” which is the least restrictive and means that anyone sent access to files/folders housed in SharePoint or OneDrive, will have the ability to access these files without logging in.



Example of over permissive sharing to external/guest user accounts

Trimarc recommends configuring these settings to one of the following options:

· New and existing guests. Guests must sign in or provide a verification code.

· Existing guests. Only guests already in your organization's directory.

· Only people in your organization. No external sharing allowed.

Multi-Factor Authentication (MFA) is not required

Yes, we still see this.

With the alarming rise in cybercrime, we know that single-factor authentication is no longer sufficient to protect any organization. Furthermore, relying on passwords alone creates extensive vulnerabilities as passwords can be compromised through phishing, brute force attacks, and human error. Despite this fact and the recommendation that all Azure AD accounts are configured to use multi-factor authentication, we frequently come across organizations where MFA is not enforced.

By not implementing MFA, organizations are at a considerable risk and potentially exposing sensitive data and resources. While there are several approaches for enforcing MFA, Conditional Access is the recommended method.

Legacy “basic” Authentication is still enabled

While Microsoft began deprecating basic/legacy auth as of December 2022, we continue to see these protocols enabled across a multitude of tenants.

Legacy authentication methods continue to be a significant security risk. Because these protocols are more prone to older attacks such as brute-forcing, legacy/basic protocols increase the risk of unauthorized access to your systems. But more importantly, legacy authentication protocols do not support modern security capabilities like multi-factor authentication.

According to a 2020 post by Microsoft Identity,

• More than 99% of password spray attacks use legacy authentication protocols like POP, SMTP, MAPI, and IMAP.

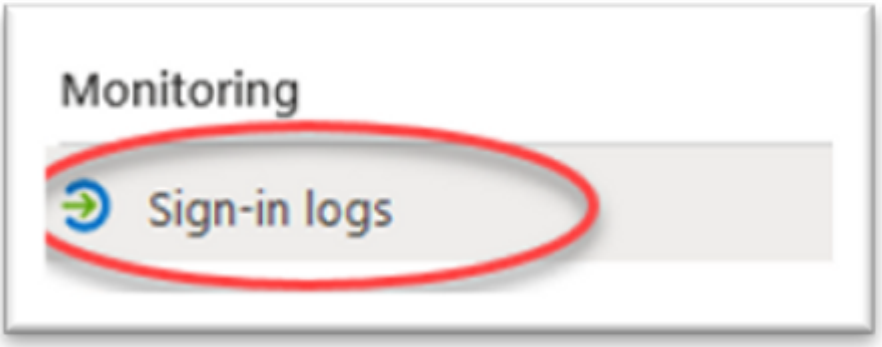
• 97 percent of credential stuffing attacks use legacy authentication

• Organizations that have disabled legacy authentication experience 67% fewer compromised than those with it enabled.

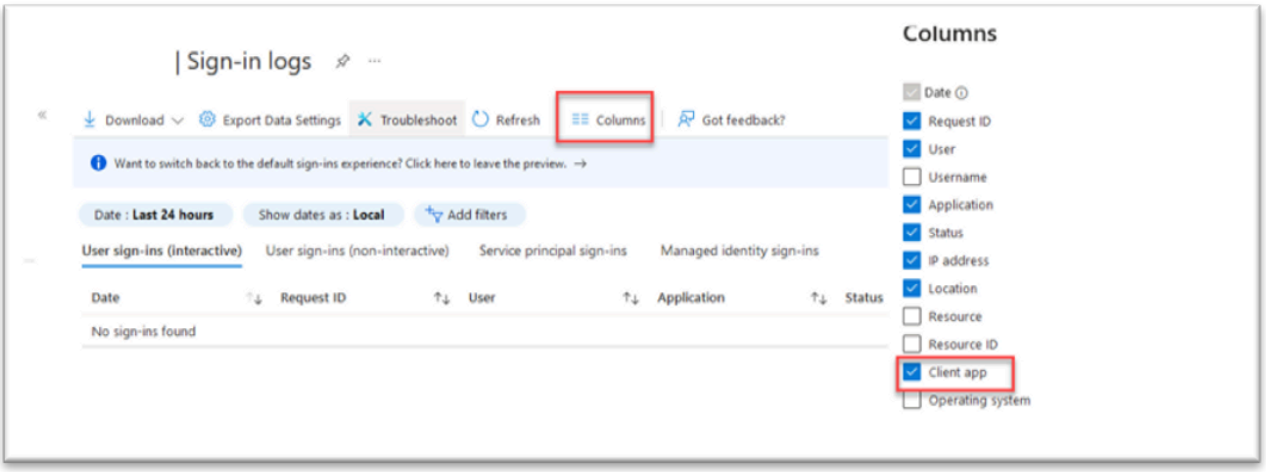
A word of advice. Before disabling legacy auth, assess the impact of blocking in your environment. Some legacy apps may not support modern authentication methods requiring you to update these systems before flipping the switch.

To identify legacy authentication use in your environment:

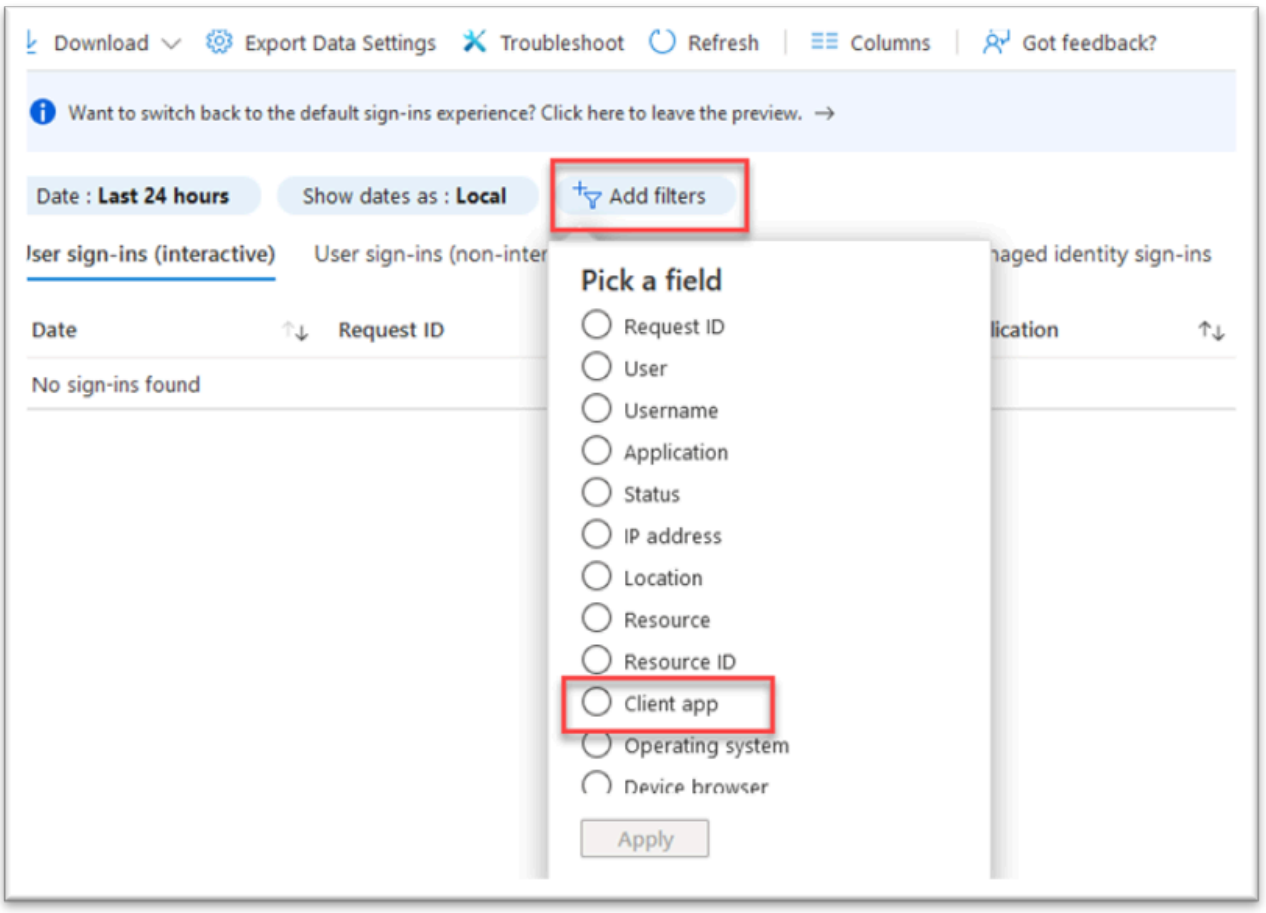
1. Navigate to the Azure AD Portal then to the Sign-in logs blade.



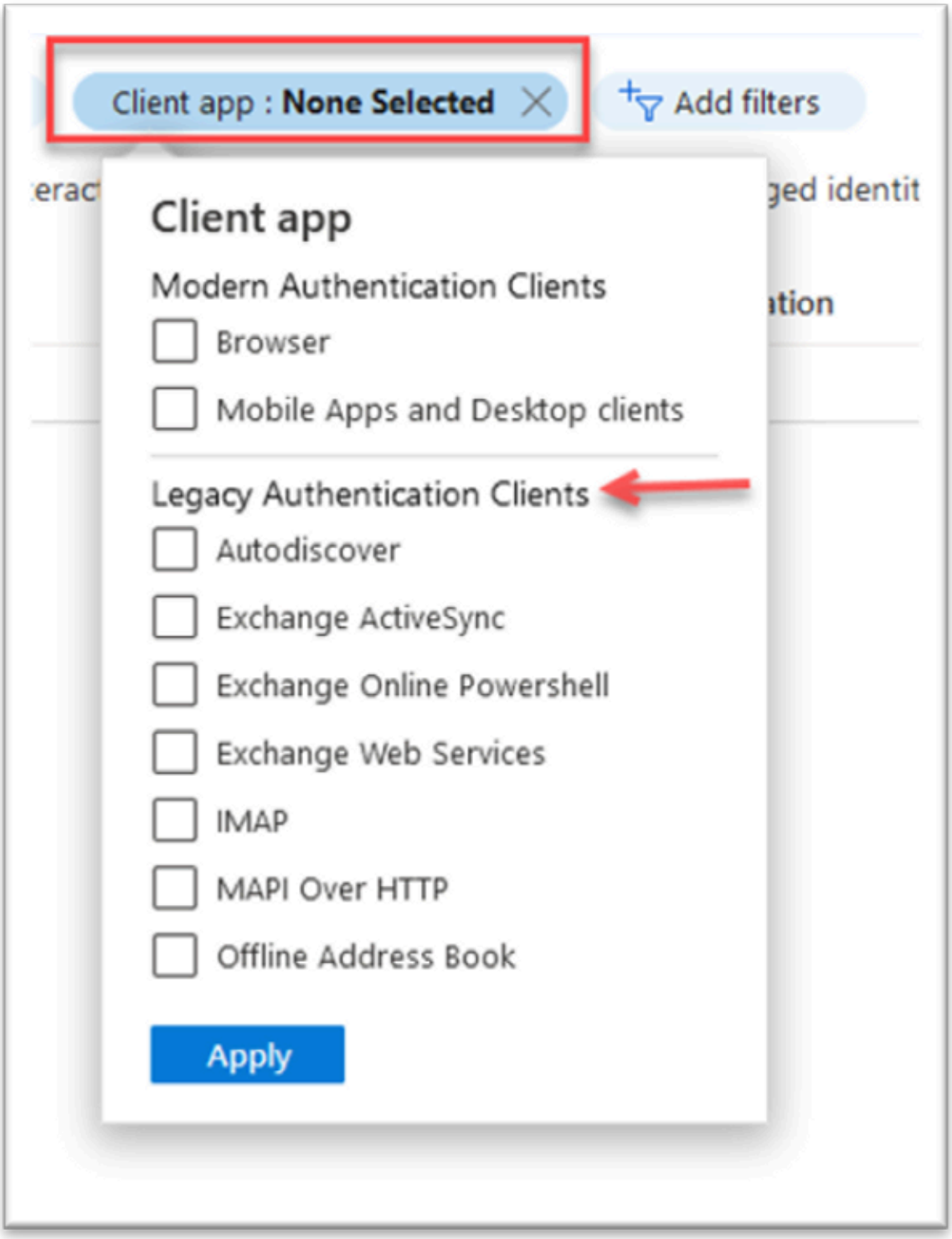
2. Select the Columns option from the top menu, then Client App (be sure to click apply).



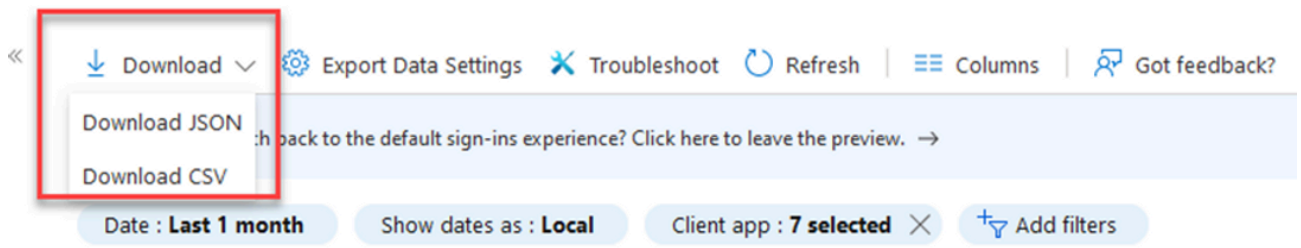
3. Select the **Add filters** option then **Client app**. Apply.



4. Select the **Client app option** (next to *Add filters*) to be presented with the list of Legacy Authentication Client options. Scroll to see the full list.



5. Select download JSON or to a CSV.

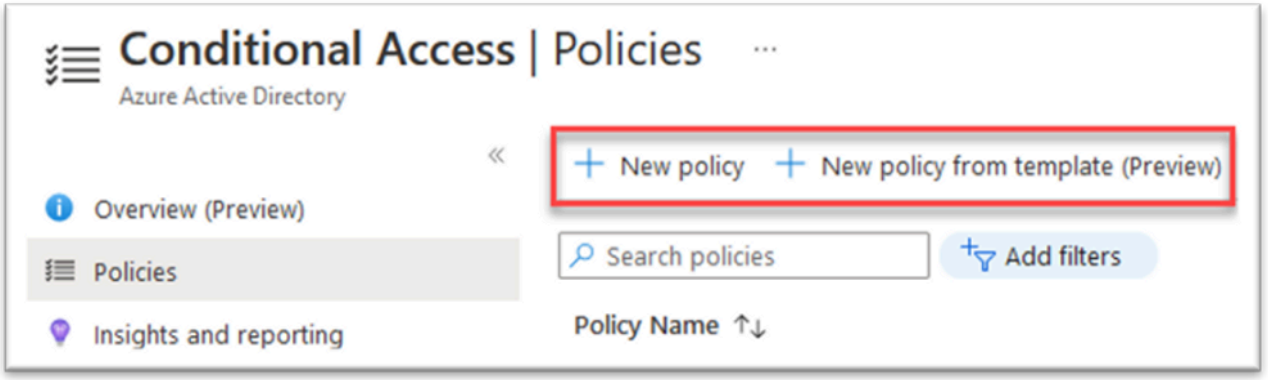


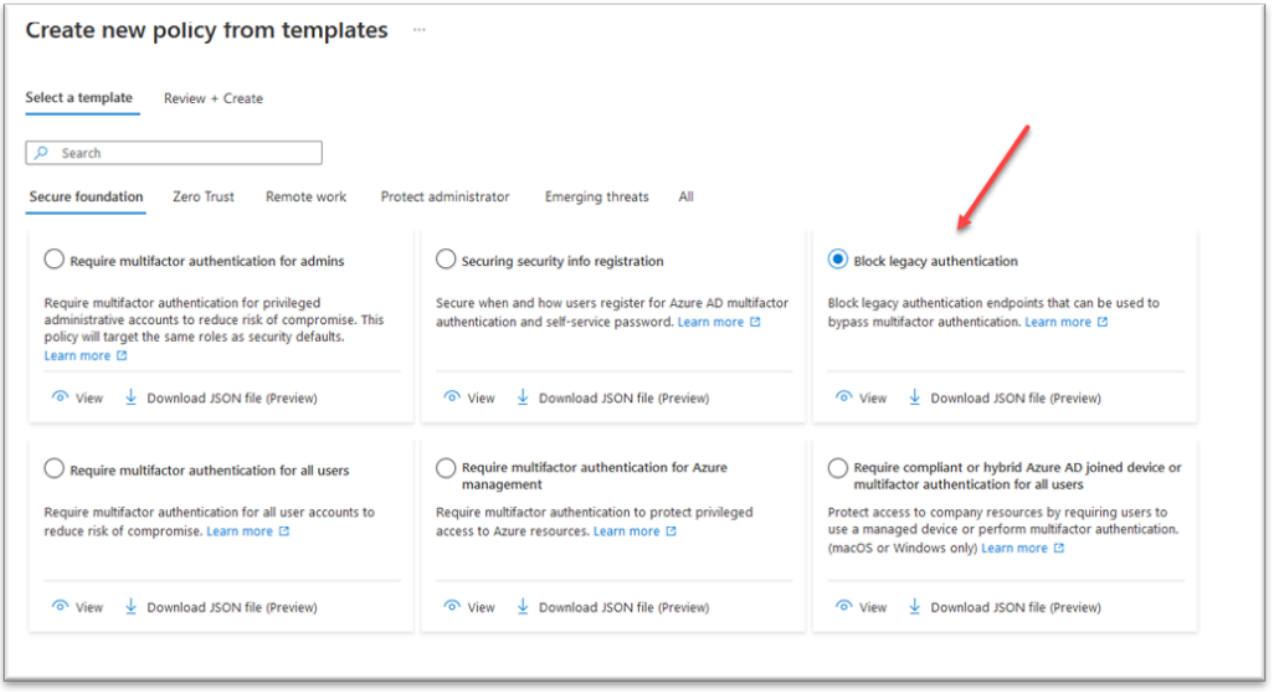
Once you have identified which client apps are leveraging legacy authentication protocols, there are [three methods for proactively blocking legacy authentication](#).

1. Security Defaults (cannot be used with conditional access policies).

2. Exchange Online Authentication Policies

3. Conditional Access Policy (create a [new conditional access policy](#) or use one of the pre-made policy templates).





Azure Portal – Within the Conditional Access Blade

No configured "Break-Glass" (Emergency access) account

During our security assessments, we typically find misconfigured break-glass accounts in the environment. In a subset of environments, we find break-glass accounts have never been created. In emergency situations, such as a security breach or a critical system

failure, normal administrative accounts may not be available or accessible. Having a break-glass account can help organizations ensure that they have a secure and reliable method for gaining access to their systems in emergency situations.

As a best practice, we recommend:

• Two cloud-only accounts (*.onmicrosoft.com) added to the Global Administrator role.

• Excluding both break-glass accounts from Conditional Access and MFA requirements.

• Enrolling in PIM with the permanent Global Administrator role assignment

• Both accounts should be stored safely and protected via strong authentication ex. FIDO2 security key versus a password. In the event this is not a possibility, configure strong passwords with no expiry for each and secure credentials in a fireproof and secure safe.

• Monitoring Azure AD logs for the use of the break-glass account(s) and configure alerts for when used.

Summary

These are just a few of the most common Azure AD misconfigurations we have seen in many environments. The good news is that many of these misconfigurations can be resolved with a low level of effort. If your organization is syncing identities to Azure AD/Microsoft 365, we recommend validating and adjusting these settings. Need help? Give us a ring.

To learn more about a comprehensive Microsoft Cloud Security Assessment of your Azure AD and Microsoft Office 365 environment, contact us.

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc Security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.